

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Governance, Compliance, and Risk (GCR) Course 3: GRC103 - Risk Assessment and Management Techniques

GRC103 Lab: The SecureBrew Risk Assessment

Group Name: Group 5

Batch No: **BATCH A/ 2025/GRC**

Date: 10/10/2025

Part A: Risk Identification

Step 1: Understand The Scenario:

Understand the environment and the business we are reviewing:

The Business: SecureBrew Coffee Shop, is a small campus-based coffee shop owned by Alex, passionate about coffee and not tech savvy, wants to modernize and keep up with the growing world and big chains.

The State of Technology: Digital Upgrade: To keep up with technology, three new tech tools were introduced, a loyalty app BeanStack, A Point of Sale (POS) which is a cloud based, processing card transaction using a Tablet and Free Public WIFI open to the public to attract students who Alex anticipates they might want to study in the café.

The Problem: The owner, Alex, has security concerns from news affecting small business like system failures, hacking, data breaches

The Task: Understanding the Risk and Formulating solutions on how to reduce the risk associated with the digital transformation, enable Alex to secure the business and to reduce risk associated with the innovation, support the business in the strategic planning of the steps ahead.

Step 2: Based on the scenario above, we have identified potential risk in the table below:

Risk ID	Category	Risk	Description
R01	Technical Failure	System Outage(Network, POS)	The cloud based POS System could go offline and this will lead to a risk in payment
R02	Technical Failure	App Downtime	If the app is inaccessible due to downtime issues the customers can't preorder, earn points and might lose trust in the digital transformation
R03	Human Error & Malice	Lack of Training leading to	Due to lack of training on compliance, security and data handling procedures, employees may accidentally mishandle the payment data which

		payment data mishandling	could result in potential damages in financial, legal and public trust.
R04	Technical Failure	Use of Weak and default Passwords leading to credential compromise	Due to lack of security training, poor password controls, weak passwords could result in credential compromise and access to sensitive data and systems.
R05	External Threat	Phishing	Staff could receive phishing emails asking for login credentials
R06	External Threat	Malware Infection due to Public WIFI	Open Wi-Fi could potentially be exploited by attackers to inject malware on unsuspecting devices
R07	Physical and Environmental	Theft of devices	A physical security breach could lead to potential loss of devices used for payment processing, i.e. the tablets
R08	Compliance and legal	GDPR Violation	Storage of clients data without proper authorization and controls could lead to potential violation of the GDPR requirements
R09	Compliance and legal	PCI-DSS non-compliance	The payment system (POS) may not meet the requirements of payment security standards, violations could lead to potential fines and or suspension of license
R10	Physical and Environmental	Coffee Spill and Damages to Routers and Systems	In a coffee shop, if the physical planning is weak, there could be potential spillage that may lead damage in system and routers if liquid were to be under controlled.
R11	Technical Failure	Lack of Backup	In dealing with finance and customer data like the loyalty points, lack of backup is a potential risk which will lead to financial losses
R12	External Threat	3 rd Party Risk	A number of risk is identified tied to third party risk like the vendors supporting the POS or The App, if affected, are there SLAs covering the loss or attack cost.
R13	Technical Failure	Data Sync Errors	If data is not confirmed to be in sync for different sessions etc., it could lead to loyalty points or transaction information not been recorded correctly.
R14	Technical Failure	Weak Encryption	If data in all it states (use, transit and rest), is not strongly encrypted it could lead to theft and misuse
R15	Human Error & Malice	Insider Threat (Malicious Act)	A disgruntled or one employee not loyal could steal customer information and data or sabotage systems.

Part B: Risk Analysis & Evaluation

Step 1: Understand the Task: Task Summary

In this section we identified the top 6 risk that if successful will result in a major business risk, then we utilized the formula given to score them based on likelihood and impact and the probability of occurrence in the next year and business consequences. And thereafter created a risk matrix to help us visualize the risk for reporting purposes.

The formula used to give likelihood and priority is as follows:

Scoring Guide:

- **Likelihood:** How probable is it that this risk occurs in the next year?
 - **Low:** Unlikely, less than 10% chance.
 - **Medium:** Might happen, 10-50% chance.
 - **High:** Very likely, greater than 50% chance.
- **Impact:** If it happens, how bad will the consequences be for SecureBrew? (Consider: Financial Loss, Operational Shutdown, Reputation Damage, Customer Loss, Regulatory Fines).
 - **Low:** Minor inconvenience, small financial loss (<\$1,000).
 - **Medium:** Significant disruption, noticeable financial loss, some negative reviews.
 - **High:** Business-threatening; major financial loss (>\$10,000), lasting reputation harm, potential legal action.

Step 2: Top Priority Risk with Scores and Justification

Risk ID	Risk	Likelihood	Impact	Risk Score	Risk Level	Justification
R01	System Outage	High 5	High 5	25	High	The business depends on cloud and internet, without these the payments are not possible
R02	App Downtime	Medium 3	High 4	12	Medium	Even though the business might continue, lack of convenience for the clients and loss of public confidence has placed this here
R05	Phishing	High 5	Medium 3	15	High	There is a high chance staff are untrained and

						phishing is a common attack vector
R08	GDPR Violation	Medium 3	High 5	15	High	Legal risk due to the customer data
R12	3 rd Party Risk	Medium 3	High 5	15	High	SecureBrew will be impacted if the service providers are impacted, also risk from 3 rd party compromise is on the rise
R14	Weak Encryption	Medium 3	High 5	15	High	If unencrypted data is breached, there will be a major legal , financial and trust damage implied.

Step 3: Risk Matrix

The SecureBrew Heat Map						
		1	2	3	4	5
LIKELIHOOD	5			15		25
	4					
	3				12 15,15,15	
	2					
	1					
IMPACT						
Green Low Risk Yellow Medium Risk Red High Risk						

Step 4: Highest 3 Priority Risk Based on the Matrix:

For our risk matrix, we identified system outage (R01) as the highest priority due to the score in high likelihood and impact on core business operations.

For the second and third highest risks, we considered the current trends in cybersecurity and the effects of legal and reputational damage, we therefore selected:

GDPR Violation(R08) Due to potential legal penalties, customer trust issues and regulatory implications.

Phishing (R05) because it is one of the most common cyberattack methods and is frequently cited in security reports especially considering the context of small employees with limited training.

Part C: Risk Treatment Strategies

Step 1: Understand the Assignment.

In this section we proceed to analyze the top priority risks we have selected in the previous risk selection process. Describe the risk and propose the treatment plan.

Step 2: Risk Treatment Based on Risk.

1. System Outage (R01):

A system or network outage which could lead to the potential loss of payment system would prevent SecureBrew from processing payment and as a result not serve the client as per the standard procedure, this would interrupt business operations, cause financial loss and customer frustration which could lead to loss of reputation and trust.

Recommended Treatment Strategy.

For the risk of system outage, we propose **Mitigate**, this is because we cannot stop using or **avoid** the POS systems and we cannot **accept** since the impact on operations is high and **transferring** the risk might lessen the troubleshooting resource needed however the downtime will not be resolved, we therefore propose **to Mitigate**.

Actions to take:

To reduce the likelihood and impact of system outages we recommend the following steps to be taken:

- a. Backup Internet connection and power alternatives: installing a backup plan for both internet and power will introduce an element of failover and recovery process which will cover the outages.
- b. Enable offline payment on the POS to continue accepting payments during outages or offer alternative means of payment and once system is restored we can carry forward.
- c. Regular checks and drill tests to confirm the failover plan is effective.
- d. Have an SLA in place with all 3rd parties to ensure a strong support and uptime.

2. Phishing (R05)

Phishing attacks target SecureBrew staff via email, SMS or in-app messages in order to steal credentials, install malware or trick staff into making fraudulent payment/transfers. When training of staff is not prioritized and the number of staff, phishing can be implemented successfully leading to account compromise, data breaches, operational disruption and reputational damage.

Recommended Treatment Strategy:

Because of the nature of the risk, phishing is very prevalent and has been one of the most successful exploitable risk by depending on exploitable human factors, in this instant, we choose

to **mitigate** because avoiding will not lessen the risk however it will increase the chance of occurrence, same as **acceptance** and **transfer** although we can transfer residual risk. We therefore propose SecureBrew to reduce the likelihood through preventions and putting controls in place, or impact through detection and response.

Actions to take:

1. **Preventative:** this will reduce likelihood, by security awareness training mandatory and tested. Through continuous measured training and testing via simulations. We can also include email filtering and anti-phishing controls, enforce strong authentication and if possible include MFA, enforce the principle of Least Privilege and Role Based Access, where access is limited to functions.

Part D: Risk Monitoring & Reporting

Risk ID	Risk Description	Likelihood	Impact	Risk Level	Treatment Strategy	Action Plan	Owner
R01	A system or network downtime affecting the payment system could affect transaction processing leading to business disruption and loss	High	High	High	Mitigate	a. Backup Internet connection and power alternatives : installing a backup plan for both internet and power will introduce an element of failover and recovery process which will cover the outages. b. Enable offline payment on the POS to continue accepting payments	The owner (Alex) The 3 rd Party Vendors

						during outages or offer alternative means of payment and once system is restored we can carry forward. c. Regular checks and drill tests to confirm the failover plan is effective. d. Have an SLA in place with all 3rd parties to ensure a strong support and uptime.	
R05	Staff could receive phishing emails asking for login credentials	High	Medium	High	Mitigate	1. Preventative: this will reduce likelihood, by security awareness training mandatory and tested. Through continuous measured training and testing via simulations . We can also include email	Owner of Café (Alex) IT and Security Consultants

						filtering and anti-phishing controls, enforce strong authentication and if possible include MFA, enforce the principle of Least Privilege where access is limited to functions.	
--	--	--	--	--	--	---	--

Part E: Management Summary

In this section, we prepare a 3-bullet summary for the owner of the café, Alex below.

TO: Alex, Owner, SecureBrew Cafe

FROM: GRC Consulting Team

SUBJECT: Key Findings from our Risk Assessment

- Our assessment identifies key risk and security issues which have to be addressed in order to secure SecureBrew Café. Our top key findings which need to be addressed immediately are inclusive of the risk to system outages and phishing.
- If the system outages occur, it could lead to a major issue with the payment and could affect transaction processing leading to business disruption and loss. If phishing is successful, it will lead to credential compromise and loss of sensitive data.
- Our top recommendation is to:
 - Backup Internet connection and power alternatives: installing a backup plan for both internet and power will introduce an element of failover and recovery process which will cover the outages.
 - Enable offline payment on the POS to continue accepting payments during outages or offer alternative means of payment and once system is restored we can carry forward.
 - Regular checks and drill tests to confirm the failover plan is effective.
 - Have an SLA in place with all 3rd parties to ensure a strong support and uptime.
 - Security Awareness and Technical Control to reduce exploitation via phishing.

Group 5 GRC Consultants

- Eniola Ibiyemi Fatimah
- Amadi Oluchi Faith
- Naomi Oluchi Edozie
- Titilayo Kwevi
- Valentine Momanyi
- Lyne Achieno Munyolo
- Sarah Onyioze Jatto
- Ene Rita Otalù
- Adanna Somtochukwu Onu
- Dolapo Odeyemi
- Najma Abdi Omar
- Lilly Adjei
- Bilkisu Hussaini
- Javeria Hassan
- Esther Kube Awuku
- Emediong Bassey
- Adejuwon Ruqoyat Adebisi
- Ojimba Anita
- Priscilla Azilafu
- Deborah Orimikoya
- Joy Wekesa
- Winner Osahenrhun Ayevbuomwan
- Okafor Chinazaekpere Miracle
- Oreofe Omowunmi Dada
- Rosemary Edet
- Olasubomi Olakunle
- Abimbola Olowoporoku
- Adeoye Adedoyin
- Toyibah Abiola Adewale